

MATRIZ DE RESPONSABILIDADE PARTILHADA NIS2

Quem é responsável por quê em IaaS, PaaS e SaaS — e o que a PME NUNCA pode delegar

Erro crítico mais comum das PMEs: pensar que "se está na Cloud, a segurança é do fornecedor". FALSO. O modelo de responsabilidade partilhada define claramente o que o fornecedor garante e o que é **sempre responsabilidade da PME** — independentemente do tipo de cloud.

Área de Responsabilidade	IaaS (Azure/AWS/Hetzner)	PaaS (App Services, DB)	SaaS (M365, Salesforce)	Crítico para NIS2?
INFRAESTRUTURA FÍSICA				
Segurança física dos datacenters (controlo de acesso, câmeras, destruição de hardware)	■ ■ Cloud	■ ■ Cloud	■ ■ Cloud	—
Disponibilidade e redundância da infraestrutura de rede	■ ■ Cloud	■ ■ Cloud	■ ■ Cloud	—
Virtualização e hypervisor seguro	■ ■ Cloud	■ ■ Cloud	■ ■ Cloud	—
CONFIGURAÇÃO E SISTEMA				
Segurança do sistema operativo das VMs (patches, hardening)	■ PME	■ ■ Cloud	■ ■ Cloud	■ ■ SIM
Configuração segura das redes virtuais (VNet, Security Groups, firewalls)	■ PME	■ PME	■ ■ Cloud	■ ■ SIM
Configuração segura da plataforma/aplicação	■ PME	■ PME	■ ■ Cloud	■ ■ SIM
Actualizações e patches da plataforma	■ PME	■ ■ Cloud	■ ■ Cloud	—
GESTÃO DE IDENTIDADES E ACESSOS				
Gestão de utilizadores, grupos e permissões (quem acede a quê)	■ PME	■ PME	■ PME	■ CRÍTICO
MFA — autenticação multifactor activada e obrigatória	■ PME	■ PME	■ PME	■ CRÍTICO
Políticas de acesso condicional (local, horário, dispositivo)	■ PME	■ PME	■ PME	■ CRÍTICO
Gestão de contas privilegiadas (admin, root)	■ PME	■ PME	■ PME	■ CRÍTICO
Offboarding de utilizadores (revogar acessos em <2h)	■ PME	■ PME	■ PME	■ CRÍTICO
PROTECÇÃO DE DADOS				
Encriptação dos dados em repouso	■ PME	■ Ambos	■ ■ Cloud	■ ■ SIM
Encriptação dos dados em trânsito (TLS)	■ Ambos	■ Ambos	■ ■ Cloud	■ ■ SIM
Classificação e gestão dos dados (o que é sensível e onde está)	■ PME	■ PME	■ PME	■ CRÍTICO

Área de Responsabilidade	IaaS (Azure/AWS/Hetzner)	PaaS (App Services, DB)	SaaS (M365, Salesforce)	Crítico para NIS2?
Backup dos dados (frequência, retenção, teste de restauro)	■ PME	■ Ambos	■ PME	■ CRÍTICO
DLP — prevenção de fuga de dados	■ PME	■ PME	■ Ambos	■ SIM
MONITORIZAÇÃO E LOGS				
Logs de auditoria de infra (hardware, rede, sistema)	■ Cloud	■ Cloud	■ Cloud	—
Logs de acesso dos utilizadores (quem acedeu, quando, o quê)	■ PME	■ Ambos	■ Ambos	■ SIM
SIEM / monitorização em tempo real de eventos de segurança	■ PME	■ PME	■ PME	■ SIM
Alertas e resposta a incidentes (detecção e notificação)	■ PME	■ PME	■ PME	■ CRÍTICO
CONFORMIDADE NIS2 / RGPD				
Conformidade da infraestrutura com normas de segurança	■ Cloud	■ Cloud	■ Cloud	—
Conformidade do uso da cloud com NIS2 e RGPD da PME	■ PME	■ PME	■ PME	■ CRÍTICO
Registo e documentação das configurações de segurança	■ PME	■ PME	■ PME	■ CRÍTICO
Notificação ao CNCS em caso de incidente	■ PME	■ PME	■ PME	■ CRÍTICO

LEGENDA	
■ PME	Responsabilidade exclusiva da PME — não pode ser delegada ao fornecedor cloud
■ Cloud	Responsabilidade do fornecedor cloud (Microsoft, AWS, Google, etc.)
■ Ambos	Responsabilidade partilhada — PME configura, fornecedor assegura a plataforma
■ CRÍTICO para NIS2	Falha nesta área = incumprimento directo NIS2 + risco de coima
■ SIM	Relevante para NIS2 — deve ser documentado e monitorizado

■ ■ **NOTA CRÍTICA NIS2:** A responsabilidade da PME perante o CNCS não diminui por usar cloud. Em caso de incidente, o CNCS pergunta: 'O que fez a PME para garantir a configuração segura dos seus serviços cloud?' Se a resposta for 'nada — assumimos que o fornecedor tratava de tudo' → incumprimento NIS2 comprovado. A **gestão de identidades (MFA), os backups, a notificação ao CNCS e a classificação de dados são SEMPRE responsabilidade da PME**, independentemente do modelo de cloud utilizado.